文件编号 File Number	文件版本 Version	密级 Confidentiality level
ERPO-IS-2021-007	V5.0	内部公开

信息安全奖惩管理规定

拟制人	周艳	**日期**	2020年12月25日
评审人	各产品线、职能、地域总监	**日期**	2021年1月29日
批准人	陈浩	**日期**	2021年2月3日
签发人		**日期**	

易宝软件有限公司

修订记录

版本号	修订日期	修订内容摘要	修改人	审核人	批准人
V5.0	2021-02-07	由《上海易宝信息安全管理制度》V4.0中的“4.违规级别”、“5.违规责任认定”内容进行细化，并独立发布。	周艳		陈浩

文件名称	信息安全奖惩管理规定V5.0			
版　本	V5.0	生效日期		2021年2月7日
文件编码	ERPO-IS-2021-007	流程架构	L1	1. 信息安全管理
拟 制 人	周艳		L2	1.1 信息安全
审 核 人	各业务/职能部门流程责任人		L3	1.1.5 安全事件管理
批 准 人	陈浩		L4	1.1.5.5 奖惩与管理问责
流程责任人	信息安全管理部总监			
适用范围	公司及所属分公司、全资子公司			

信息安全奖惩管理规定

1. 目的

为明确信息安全奖励与惩罚的定级规则及操作原则，加强相关工作的规范性，特制定本管理规定，促进员工信息安全意识提升。

2. 概述

本管理规定对信息安全奖励与违规行为的定级规则及操作原则进行了细化，并对相应的奖励与违规业务场景作了详细描述，确保所有的信息安全事件处理有章可循、有据可依，责任清晰、安全合规。

3. 术语和定义

术语	定义
信息安全事件	指识别出的发生的系统、服务或网络事件表明可能违反信息安全策略或防护措施失效；或以前未知的与安全相关的情况；其中一、二级信息安全事件称为重大信息安全事件。
信息安全活动	为培养员工信息安全意识，提高公司整体安全水平而举办的活动，形式包括但不限于：考试、培训、宣传和自检。
第三方	指除公司、公司的客户、违规员工本人以外的其他个人或组织。
恶意违规	以个人获利或损害公司利益为目的的违规行为。
手段恶劣	指故意逃避信息安全监管的泄密行为。
情节严重	违规过程和结果在公司内或社会上影响大、程度深、范围广。

4. 职责与权限

角色	职责
员工	遵守公司信息安全管理制度，积极配合、参与信息安全活动。
各部门兼职信息安全专员	• 负责信息安全管理制度在本部门的宣传与培训工作； • 负责对本部门的信息安全问题进行汇总与反馈。
各级部门主管	• 是部门信息安全的第一责任人，负责监督和管理本部门员工的信息安全行为，并对潜在的信息安全风险进行预警，预防信息安全事件； • 对本部门因管理失职导致的信息安全事件负管理连带责任。
各区域信息安全专员	对本区域信息安全事件进行调查、核实及跟踪处理，确定事件责任人并输出《信息安全事件调查报告》。
各区域信管主任	负责审核本区域的《信息安全事件调查报告》。
信息安全经理	负责复核《信息安全事件调查报告》。
信息安全总监	负责签发《信息安全事件调查报告》。

5. 内容

5.1 奖励、违规行为处罚原则

5.1.1 及时激励原则

5.1.1.1对长期妥善保护公司信息资产，有效避免信息资产的遗失、滥用、盗用等，或对于促进信息安全合理共享表现突出的个人或者集体，将及时奖励。

5.1.1.2信息安全管理部根据员工意识教育工作的需要，可不定期组织专项信息安全氛围建设活动，给予适当的及时激励。

5.1.2 举报保密原则

对于举报信息安全违规行为的人员，将对其进行奖励并严格保护其个人资料不公开。

5.1.3 违规行为处罚原则

5.1.3.1法律追究原则

公司所有保密信息均为公司合法资产，受国家法律法规保护。任何损害公司保密信息的行为，公司均有权追究行为人法律责任。

5.1.3.2违规定级原则

根据违规行为的性质、造成的损失和影响的严重程度、违规人员是否有意对违规行为分级。涉及关键

信息资产的，违规等级要升级；一次违反多条信息安全规定的人员按最高违规等级从重处罚；对多次违反信息安全规定的人员再次违规时要从重处罚。

5.1.3.3主动从宽原则

产生违规行为后主动报告，积极采取补救措施以减少影响和损失的人员，可视情况减轻处罚或免予处罚；对问题隐瞒不报或者不及时上报而导致违规影响扩大的人员，加重处罚。

5.1.3.4过度防卫处罚原则

对阻碍信息合理流动与共享的人员要给予处罚。

5.1.3.5及时处理原则

对重大信息安全违规事件，要及时处理。任何拖延、推诿不处理的责任人，要给予问责。

5.2 奖励等级与责任部门

5.2.1 奖励等级与措施

奖项类型	奖励等级	奖励事迹	奖励措施
集体奖	一级	举报或者制止泄密、窃密或者其他严重损害公司利益事件的集体。	根据具体情况给予3000元奖励（遵循“举报保密原则“淡化事迹并隐藏人员信息）。
	二级	在信息安全方面做出表率或者突出贡献的集体。	根据具体情况给予2000元奖励通报表扬（遵循“举报保密原则“淡化事迹并隐藏人员信息）。
	三级	在信息安全方面做出贡献的集体。	根据具体情况给予1000元集体奖。
个人奖	一级	举报或者制止泄密、窃密或者其他严重损害公司利益事件的个人	1000元，通报表扬（遵循“举报保密原则“淡化事迹并隐藏人员信息）
	二级	制止他人违规行为或者即时反映可能造成泄密、窃密或者其他重大安全隐患的个人。	600元，通报表扬（遵循“举报保密原则“淡化事迹并隐藏人员信息）
	三级	在信息安全管理中做出贡献，反映信息安全隐患或者过度防卫被核实、提出信息安全合理化建议并被采纳的个人	300元，通报表扬（遵循“举报保密原则“淡化事迹并隐藏人员信息）

5.2.2 奖励责任部门

5.2.2.1 对于满足信息安全奖励标准的集体或者个人，信息安全管理部可根据具体事迹定期进行申报，审批通过后由人力资源部根据公司财务制度进行发放奖金；

5.2.2.2 各部门信息安全第一责任人可自行组织对本部门优秀信息安全集体或者个人进行奖励。

5.3 违规定级原则与责任部门

5.3.1 违规定级原则：以信息安全违规行为造成的影响和风险作为定级基础，通过信息密级和扩散范围确定影响和风险。

5.3.2 加重或减轻原则：根据违规动机、手段、情节、被调查人员配合态度等予以加重或减轻处理，确定最终违规等级。

5.3.3 管理连带原则：在事件调查过程中、核实过程中、短期内频发的违规或泄密事件，违规人直接主管或PM及相关管理者须承担管理连带责任。

5.3.3 判例法原则：在不违背信息安全违规定级标准和原则的前提下，公司信息安全管理部可参照判例进行违规等级认定。

6. 定级

6.1 违规定级

根据信息安全违规行为所涉及的信息密级和扩散范围进行初步定级，初步定级后，参照加重或减轻处理标准对定级结果进行调整，确定最终违规等级。

违规行为不涉及加重或减轻处理的，初步定级结果就是最终违规等级。

6.1.1 初步定级

1）涉及保密信息扩散违规行为，依据下表初步定级：

密级[注1]	扩散范围[注2]			
	公司外			公司内
	竞争对手	第三方	员工私人存储介质或信息系统	
绝密	一级违规	一级违规	一级违规	三级违规
机密	一级违规	一级违规	二级违规	四级违规
秘密	一级违规	二级违规	三级违规	-
内部公开	二级违规	三级违规	四级违规	-

注1：信息密级依据《信息保密管理规定》确定。

注2：信息扩散范围分为公司外和公司内，公司外扩散范围包括竞争对手、第三方、员工私人存储介质和信息系统。

2）对于未涉及保密信息扩散，但违反公司信息安全相关管理规定的行为，根据违规行为所造成的影响和风险，初步定级为三级违规或四级违规。

3）轻微违规：对初步定级为三、四级，未造成实际风险和影响，且员工无主观恶意的违规行为可以按轻微违规定级，实行快查快处。

6.1.2 加重标准

1）有下列情形之一的，应加重至一级违规

- 属于以下恶意违规行为
  - 将保密信息透露给竞争对手，损害公司利益；
  - 出售保密信息给任何第三方；
  - 未经批准，利用保密信息在公司外从事咨询、授课并获利；
  - 利用岗位职权违规；
  - 未经公司合规性审查，私自与第三方商洽购买反向工程报告；
  - 其他利用保密信息谋取个人利益的行为。
- 属于以下情节特别严重的违规行为
  - 破坏设备及设施获取保密信息；
  - 胁迫或者教唆他人实施违规行为；
  - 未经商业秘密拥有方事先书面授权许可，擅自在产品开发或第三方合作中引入前述保密信息；
  - 未经客户事先书面授权许可，私自在客户的非公开区域进行拍摄、录像、拷贝或其他类似行动。

2）有下列情形之一的，加重一级

- 属于以下手段恶劣的违规行为
  - 绕过公司安全控制系统；
  - 盗窃他人信息系统账号；
  - 未经批准，通过拍照、录音、摄像方式获取保密信息；
  - 夹带、更改文件名、更改文件后缀。
- 属于下列情节严重的违规行为
  - 涉及文档数量大（内部公开信息超过 500M 或 50 篇，或秘密级及以上信息超过 5 篇）；
  - 在 2 人以上的共同违规行为中起主要作用；
  - 6 个月内有两次及以上违规；
  - 提供工作便携机、信息系统账号密码给外部人员，导致公司信息资产泄露；
  - 将公司保密信息直接或间接提供给外部媒体或扩散到互联网，对公司造成恶劣影响；
  - 蓄意收集并外发公司保密信息。
- 存在以下不配合调查的行为
  - 调查过程中有隐瞒、伪造、销毁证据的行为；

- □ 否认、拒绝承认事实；
- □ 在违规事实清晰确凿的情况下，不配合公司调查程序签署《违规情况说明和不扩散承诺书》、《同意配合检查并删除公司信息资产承诺书》、《信息资产持有情况表》；
- □ 不配合公司采取消除泄密隐患的控制措施；
- □ 调查中有其他不诚信的行为。

6.1.3 减轻标准

1）在公司启动调查前主动申报违规行为，未造成严重后果的可减轻或免除处分；

2）在规定时间内彻底坦白违规行为，或有举报其他信息安全违规或泄密线索、反馈信息安全隐患等情节，且核实属实的立功表现行为的，可从轻或减轻处分；

4）属于以下过失违规的行为的，可从轻定级或减轻一级处分；

- □ 因个人保管不当，丢失存放保密信息的存储介质造成的信息扩散；
- □ 由于个人疏忽导致保密信息不当扩散；
- □ 工作需要，但未按流程要求外发或拷贝保密信息。

5）减轻处分最低降至四级违规，主动申报的四级违规可从轻或免除处分。

6.2 处罚标准

违规等级	处罚措施
一级违规	1、 公司全员通报、解除劳动合同 2、 记录黑事件 3、 公司将按最低 100 万元人民币的损失标准予以追偿 4、 如触犯国家法律法规，公司依法追究或保留追究其法律责任的权利
二级违规	1、 公司全员通报、季度绩效考核结果为 D、当次调薪周期延长 24 个月 2、 记录黑事件 3、 公司将按最低 30 万元人民币的损失标准予以追偿 4、 如触犯国家法律法规，公司依法追究或保留追究其法律责任的权利
三级违规	1、 产品线及地域通报、季度绩效不高于 B、当次调薪周期延长 18 个月 2、 记录黑事件 3、 公司将按最低 10 万元人民币的损失标准予以追偿 4、 如触犯国家法律法规，公司依法追究或保留追究其法律责任的权利
四级违规	1、 产品线及地域通报、季度绩效不高于 B，当次调薪周期延长 12 个月 2、 记录黑事件 3、 公司保留按最低 1 万元人民币的损失标准予以追偿的权利 4、 如触犯国家法律法规，公司依法追究或保留追究其法律责任的权利
轻微违规	1、 管理层通报 2、 信息安全违规人员考试

6.3 对管理责任人的问责

6.3.1 问责事项

对于信息安全违规事件，若存在管理不力或知情不作为等情形的，将对违规责任人的直接管理者和/或间接管理者进行管理连带问责。

6.3.2 问责形式

依据易宝《安全合规问题处理办法》、《安全合规问题处罚措施执行指南》进行问责，具体由安全合规组进行裁决。

6.3.3 加重或减轻原则

- 有下列情形之一的，应当问责或从重处分
  - 干扰、妨碍违规事件调查；
  - 包庇违规人员；
  - 打击报复举报人、证人及其他人员；
  - 对立项调查的项目，未经调查小组同意，擅自调查和自行询问相关人员，造成不良后果；
  - 其他不诚信行为。
- 有下列情形之一的，可以减轻处分或免除问责
  - 能够主动发现并申请调查且积极协助调查；
  - 任期不满3个月的。

7. 违规及处理

依据《信息安全事件响应流程》执行。

8. 其它

1) 此文件发布前已经正式发布的各文件中，与本文件相冲突的，以此文件为准；
2) 各产品线/区域/部门可在遵循本制度的前提下，根据本组织的情况制定操作细则；
3) 本制度自签发之日起执行，最终解释权归属信息安全管理部。

9. 相关文件

序号	文件编码	文件名称
1	ISM-IS-15-153-P01	信息安全事件响应流程

10. 记录的保存

记录名称	移交责任人	保存责任人	保存场所	归档时间	保存期限	到期处理方式

易宝软件有限公司

2020年12月25日

附件：信息安全常见违规行为及其适用处分等级举例

1. 一级违规

1.1 出卖公司或客户的保密信息给任何第三方；
1.2 未经批准，利用公司或客户的保密信息在外部从事咨询、授课活动；
1.3 未经批准，发送绝密信息或核心资产到私人外部邮箱或拷贝到私人存储介质中；
1.4 未经批准，将公司或客户的机密信息泄露到任何第三方；
1.5 未经批准，使用拍照、录音、摄像等手段获取公司或客户的大量秘密信息；
1.6 未经批准，编制或故意运行黑客、病毒程序，攻击公司或客户的网络或信息系统；
1.7 违反公司或客户的管理要求，尚未获取事先书面同意，私自在产品开发或第三方合作中引入未经授权的信息；
1.8 违反公司或客户的管理要求，尚未获取事先书面同意，私自在公司或客户的实验区、会议室、机房、站点等场所拍摄、录像、拷贝或其他类似活动。

2. 二级违规

2.1 泄露公司或客户的内部公开信息给竞争对手
2.2 未经批准，上传公司或客户的秘密信息到外部公开信息系统或泄露给任何第三方
2.3 未经批准，发送机密信息到员工私人信息系统或拷贝到私人存储介质中
2.4 办理离职期间，未经批准，通过邮件外发、拷贝或打印等方式获取公司或客户的秘密信息。
2.5 未经批准，通过私人 U 盘或光盘启动存放有公司或客户的秘密信息的计算机。
2.6 未经批准，私自更换公司或客户的计算机硬盘并将硬盘中的秘密信息拷贝到私人存储介质
2.7 未经批准，传播破解、攻击公司或客户的安全系统的方法。
2.8 未经公司或客户的合规性审查，私自与第三方商洽购买反向工程报告。
2.9 违反公司或客户的管理要求，私自通过提供实物、邮件外发、拷贝或打印等方式向第三方传递外来非公开信息（包括样品、器件、技术文档等）。
2.10违反公司或客户的管理要求，私自发送外来非公开信息到员工私人外部邮箱或拷贝到私人存储介质。
2.11假报公司或客户的便携机丢失，且便携机中承载内部公开文档大于 50 篇或 500M。

3. 三级违规

3.1 未经批准，发送秘密信息到员工私人外部邮箱或拷贝到私人存储介质中。
3.2 未经批准，上传公司或客户的内部流程文档至外部公开信息系统或泄露给任何第三方
3.3 办理离职期间，未经批准，通过邮件外发、拷贝或打印等方式获取公司或客户的内部公开信息。
3.4 未经批准，通过私人 U 盘或光盘启动存放有公司或客户的内部公开信息的计算机。
3.5 未经批准，发送绝密信息或核心资产给公司或客户的内未授权访问人员
3.6 未经批准，在同一台机器上安装两个或以上的操作系统，且至少一个操作系统未按公司或客户的要求安装安全控制系统。
3.7 未经批准，将故障硬盘带出公司或客户的进行维修。
3.8 未经批准，拆除计算机封条或安全机箱。
3.9 将原工作单位的非公开信息拷入公司或客户的电脑或者信息系统。
3.10违反公司或客户的管理要求，私自在电脑或信息系统、办公场所中保存外来非公开信息。
3.11违反公司或客户的管理要求，明知或应知自己不在被授权范围，仍私自向授权范围以内的人员索要并保留外来非公开信息。

3.12违反公司或客户的管理要求，私自将外来非公开信息上载到公司或客户的内部公开的平台。

4. 四级违规

4.1 未经批准，拷贝公司或客户的流程文档或内部培训材料等内部公开信息到私人的存储介质或信息系统中。

4.2 未经批准，发送机密级信息给公司或客户的内未授权访问人员。

4.3 未经批准，转借公司或客户信息系统的个人帐户给外部人员使用。

4.4 私自持有更换下来的故障硬盘，未按公司或客户的流程低格或物理销毁。

4.5 未经批准，作为信息持有人，在信息获取流程审批通过后五个工作日内无故不提供信息。

4.6 计算机（或系统）感染病毒并攻击其它计算机，IT 通知其整改后，在三个工作日内不整改。

4.7 私自收集他人域账号口令但尚未实际使用。

4.8 违反公司或客户的管理要求，项目结束或转岗时，未删除该项目外来非公开信息。

4.9 违反公司或客户的管理要求，私自通过提供实物、邮件、拷贝或打印等方式向 3 名以内内部员工传递外来非公开信息（包括样品、器件、技术文档等）。

5. 轻微违规

5.1 违规定级为三级或四级中，违规涉及文档不超过 50 篇，不涉及机密级及以上信息，且同时符合以下三种场景之一的违规，可按轻微违规认定。

1） 入职三个月且未转正的新员工

2） 属于工作需要的过失违规

3） 在调查中有彻底坦白的情节

5.2 因更换电脑、清理电脑硬盘空间或工作交接需要转移数据导致的违规，不涉及机密及以上信息，且同时符合以下两点的，可按轻微违规认定。

1)有充分证据表明员工在正常数据转移过程（iDesk 、onebox、USB 加密写等方式）中出现了技术问题，求助 IT 没有解决问题或没有及时获得 IT 支持后，才通过私人设备或信息系统进行了数据转移。或有充分证据表明当时由于特殊原因，员工不能使用正常的数据转移手段。

2)操作完成后无扩散，且在调查前员工已删除了私人设备或信息系统中的相关数据。

5.3 有以下情形之一的，不能按轻微违规认定。

1) 非首次违规

2) 明知故犯的（如操作前已有主管或同事明确告知、或咨询过相关人员）

3) 使用以下手段违规：

通过拍照、录像、截图等方式；

修改文件名、文件后缀、夹带等方式；

使用绕过公司或客户的安全控制系统的方式；

盗窃他人账号违规。

4）在调查中有不配合、不诚信或销毁证据的行为。